



MANUAL DE PERFILES, USUARIOS Y CONTROL DE ACCESO DEL CRM

Arquitectura recomendada, alta de usuarios, permisos, seguridad y pruebas

Documento operativo para administración del sistema

Edición: agosto de 2026

Respuesta directa

Todos los perfiles deben usar la misma carpeta, la misma publicación y la misma URL. El CRM identifica al usuario después del inicio de sesión y habilita únicamente los apartados y operaciones permitidos. No se deben mantener copias separadas del sistema por área.

Contenido

1. Decisión de arquitectura: una sola carpeta
2. Cómo funciona el acceso de extremo a extremo
3. Roles actuales y matriz de páginas
4. Alta de un usuario nuevo
5. Asignación y modificación de roles
6. Seguridad real: interfaz, guardas y RLS
7. Prueba de cada perfil antes de producción
8. Administración cotidiana de usuarios
9. Implementación en Internet
10. Crecimiento a permisos más detallados
11. Solución de problemas
12. Listas de comprobación y fuentes oficiales

1. Decisión de arquitectura: una sola carpeta

La estructura correcta para Skilled es un único CRM publicado una sola vez. Todos los usuarios abren la misma dirección; el sistema decide qué ve y qué puede hacer cada persona después de identificarla.

No crear carpetas por perfil

No uses una carpeta para Almacén, otra para Compras y otra para Proyectos. Eso duplica errores, hace difícil actualizar el sistema y puede dejar versiones contradictorias en producción.

Elemento	Configuración recomendada	Motivo
Código del CRM	Una carpeta y un repositorio privado	Todas las áreas reciben las mismas correcciones.
Publicación	Una URL, por ejemplo <code>crm.skilledmx.cloud</code>	El inicio de sesión determina el perfil.
Base de datos	Un proyecto de Supabase	Materiales, proyectos, herramientas y usuarios comparten trazabilidad.
Identidad	Una cuenta por persona	Permite saber quién realizó cada operación.
Permisos	Perfil + guardas + RLS	Ocultar un botón no es suficiente; la base también debe protegerse.

Estructura de publicación

Usuario -> `https://crm.skilledmx.cloud`

- > `login.html`
- > Supabase Auth
- > `perfiles_usuario`
- > `auth-guard.js`
- > `skilled-sidebar.js`
- > políticas RLS de Postgres

- La carpeta contiene todos los HTML, JavaScript, CSS, imágenes y manuales operativos.
- La barra lateral filtra los enlaces según el rol.
- El guardián de acceso bloquea una URL directa no permitida.
- Las políticas RLS deciden si la consulta o modificación de datos está autorizada.

2. Cómo funciona el acceso de extremo a extremo

- Inicio de sesión:** La persona escribe correo y contraseña en `login.html`.
- Autenticación:** Supabase Auth valida la identidad y emite una sesión con token.
- Perfil operativo:** El CRM consulta `public.perfiles_usuario` para obtener nombre, rol, departamento y estado activo.
- Protección de página:** `auth-guard.js` compara el archivo solicitado contra la matriz del rol.
- Navegación:** `skilled-sidebar.js` presenta únicamente los apartados permitidos.
- Protección de datos:** Las políticas RLS y funciones SQL autorizan o rechazan las operaciones en la base.
- Trazabilidad:** Los movimientos y asignaciones registran al responsable identificado.

Importante

Supabase Auth identifica a la persona, pero la autorización de datos debe completarse con RLS. El token del usuario puede utilizarse para limitar filas y acciones en Postgres.

3. Roles actuales y matriz de páginas

La versión actual reconoce cinco perfiles operativos además del administrador. La matriz siguiente resume la intención funcional; antes de producción debe compararse con auth-guard.js, skilled-sidebar.js y las políticas RLS.

Rol	Alcance	Uso recomendado
Administrador	Acceso total	Configuración, pruebas, usuarios y todos los módulos.
Jefe de almacén	Operación completa de almacén	Materiales, compras, movimientos, proyectos, herramientas, vehículos, reportes y pruebas controladas.
Almacén	Operación cotidiana	Inventario, movimientos, compras, herramientas, proyectos y vehículos según políticas.
Compras	Abastecimiento	Consulta de catálogo, bajo mínimo, órdenes, reportes, activos y herramientas relacionadas.
Proyectos	Control de proyectos	Proyectos, solicitudes, reportes, historial y activos asignados.
Consulta	Lectura limitada	Inicio, catálogo, reportes, herramientas, vehículos y manual.

Páginas relevantes por área

- Cuenta: Inicio, perfil y escáner.
- Materiales: Catálogo, importación, bajo mínimo, almacenes y etiquetas.
- Movimientos: Registrar movimiento, historial y tomas físicas.
- Compras: Entrega directa, solicitudes y órdenes de compra.
- Proyectos: Proyectos, presupuesto o plan de materiales y reportes.
- Herramientas: Catálogo, unidades, asignaciones, estado e historial.
- Vehículos: Flotilla, salidas, pasajeros, combustible y gastos.
- Ayuda: Manual de usuario.

4. Alta de un usuario nuevo

Método recomendado desde Supabase Dashboard

13. Abre el proyecto de Supabase correspondiente al CRM.
14. Entra a Authentication > Users.
15. Presiona Add user y selecciona la creación de usuario por correo.
16. Escribe un correo corporativo único. No compartas una cuenta entre varias personas.
17. Asigna una contraseña temporal robusta y activa la confirmación del correo cuando el alta sea administrativa.
18. Confirma que el usuario aparezca en auth.users.
19. Asigna el rol en public.perfiles_usuario mediante la función autorizada.
20. Pide a la persona que inicie sesión y actualice su perfil y contraseña.

Cuenta individual

Una cuenta compartida impide saber quién recibió material, aprobó una orden, asignó una herramienta o registró un gasto de vehículo.

Ejemplo: asignar Jefe de almacén

```
select public.crm_asignar_rol_por_correo(  
  'nombre@skilled.mx',  
  'jefe_almacen',  
  true  
);
```

Verificación

```
select  
  u.email,  
  p.nombre,  
  p.rol,  
  p.activo  
from auth.users u  
left join public.perfiles_usuario p on p.id = u.id  
where lower(u.email) = lower('nombre@skilled.mx');
```

5. Asignación y modificación de roles

Los nombres técnicos deben mantenerse exactamente como los espera el CRM: administrador, jefe_almacen, almacen, compras, proyectos y consulta.

- administrador
- jefe_almacen
- almacen
- compras
- proyectos
- consulta

Cambiar de rol

```
select public.crm_asignar_rol_por_correo(  
  'persona@skilled.mx',  
  'compras',  
  true  
);
```

Desactivar acceso sin borrar historial

```
update public.perfiles_usuario  
set activo = false, updated_at = now()  
where id = (  
  select id from auth.users  
  where lower(email) = lower('persona@skilled.mx')  
);
```

Preferencia de auditoría

Cuando una persona deja la empresa, desactiva el perfil antes de eliminar la identidad. Los movimientos históricos deben conservar la referencia del responsable.

6. Seguridad real: interfaz, guardas y RLS

La protección debe existir en capas. La barra lateral mejora la experiencia, pero no es una barrera de seguridad por sí sola.

- 1. Interfaz: Oculta botones y enlaces que no corresponden.
- 2. auth-guard.js: Evita abrir una página no autorizada mediante URL directa.
- 3. RLS: Restringe SELECT, INSERT, UPDATE y DELETE en las tablas.
- 4. Funciones RPC: Validan reglas complejas como stock, reservas y movimientos.
- 5. Storage RLS: Protege PDF, comprobantes, fotografías y avatares.
- 6. Auditoría: Conserva fecha, usuario, motivo, proyecto y documento relacionado.

Llaves de Supabase

La publishable key puede estar en el navegador cuando RLS está correctamente habilitado. Las secret keys o service_role nunca deben colocarse en HTML, JavaScript público, GitHub ni Cloudflare Pages.

Patrón mínimo de una política

```
alter table public.ejemplo enable row level security;
```

```
create policy "usuarios autenticados consultan"
on public.ejemplo
for select
to authenticated
using (true);
```

Este ejemplo solo ilustra la sintaxis. En producción las condiciones deben depender del usuario, perfil, proyecto o área autorizada.

7. Prueba de cada perfil antes de producción

Crea al menos una cuenta de prueba por rol. Utiliza una ventana privada diferente para evitar que la sesión anterior quede almacenada.

Prueba	Resultado esperado	Evidencia
Inicio de sesión	Abre Inicio con nombre y rol correctos.	Captura del encabezado.
Barra lateral	Solo aparecen módulos permitidos.	Lista visible por rol.
URL directa	Una página prohibida redirige o bloquea.	Mensaje sin permiso.
Consulta de datos	Solo devuelve información autorizada.	Resultado de búsqueda.
Modificación	Una operación permitida guarda; una prohibida falla.	Mensaje y registro.
Documentos	El usuario accede únicamente a sus PDF autorizados.	Prueba de Storage.
Cerrar sesión	El enlace directo vuelve a login.	Ventana privada.

Prueba crítica de borrado

- Solo Administrador y Jefe de almacén deben ver las acciones de eliminación de registros de prueba.
- No se debe permitir eliminar herramientas con unidades, unidades con historial, vehículos con viajes u órdenes con dependencias no controladas.
- En producción, utiliza desactivar, cancelar o dar de baja cuando exista trazabilidad histórica.

8. Administración cotidiana de usuarios

Alta

- Crear identidad en Authentication.
- Asignar perfil y rol.
- Probar el acceso.
- Registrar responsable que autorizó el alta.

Cambio de área

- Cambiar el rol.
- Cerrar sesiones activas si el cambio es inmediato.
- Probar la nueva matriz.

Baja temporal

- activo=false.
- Conservar identidad e historial.
- Documentar motivo y fecha.

Baja definitiva

- Respalidar datos.
- Desactivar primero.
- Eliminar Auth solo si la política interna lo permite.

Contraseña

- Usar recuperación o cambio desde perfil.
- Nunca compartir contraseñas por texto abierto.

9. Implementación en Internet

La misma publicación sirve a todos los perfiles. El frontend puede alojarse en Cloudflare Pages y conectarse a un único proyecto de Supabase.

Repositorio privado de GitHub

-> Cloudflare Pages

-> <https://crm.skilledmx.cloud>

-> Supabase Auth + Database + Storage

21. Publica la carpeta completa del CRM, no subcarpetas por rol.
22. Configura Site URL y Redirect URLs en Supabase Authentication.
23. Mantén la publishable key en skilled-supabase.js y nunca una secret key.
24. Prueba HTTPS, cámara, PDF, descargas y sesión desde una red externa.
25. Usa una rama de desarrollo o un proyecto preview antes de publicar a main.

Una URL, muchos perfiles

El perfil no depende de una carpeta diferente; depende de la identidad autenticada y de las reglas de autorización.

10. Crecimiento a permisos más detallados

Cuando existan más áreas, la matriz fija por páginas puede evolucionar a un modelo de permisos por acción.

roles
permisos
rol_permisos
perfiles_usuario

Ejemplos de permiso:

materiales.ver
materiales.editar
movimientos.registrar
compras.aprobar
vehiculos.registrar_gasto
usuarios.administrar

- La barra lateral consulta permisos para mostrar módulos.
- Los botones consultan permisos para habilitar acciones.
- RLS o funciones SQL vuelven a verificar el permiso en la base.
- Los custom claims pueden incluir un rol en el JWT para optimizar políticas, mediante un Auth Hook.

Migración gradual

No es necesario rediseñar todo de inmediato. Primero estabiliza los seis roles actuales y después migra acciones sensibles a una tabla de permisos.

11. Solución de problemas

Síntoma	Revisión recomendada
Invalid login credentials	El correo no existe o la contraseña no coincide. Verifica Authentication > Users.
La cuenta entra pero vuelve a login	Falta el perfil público, está inactivo o el guard no pudo consultarlo.
No aparece un apartado	Revisa el rol en perfiles_usuario, auth-guard.js y skilled-sidebar.js.
Aparece el enlace pero la consulta falla	La política RLS o el permiso SQL no autoriza la operación.
El rol cambió pero sigue igual	Cierra sesión, borra caché de perfil y vuelve a entrar.
Un usuario ve demasiado	Corrige simultáneamente matriz de páginas y RLS; ocultar la barra no basta.
Error al crear usuario	Revisa triggers personalizados sobre auth.users y permisos de perfiles_usuario.
PDF no abre	Revisa políticas del bucket y que el registro guarde ruta o URL correcta.

12. Listas de comprobación y fuentes oficiales

Antes de dar acceso

- Correo corporativo confirmado.
- Perfil público creado.
- Nombre, puesto y departamento completos.
- Rol correcto.
- activo=true.
- Prueba de login realizada.
- Páginas permitidas verificadas.
- Operaciones prohibidas rechazadas por RLS.

Antes de producción

- Una sola carpeta y URL.
- Repositorio privado.
- Sin secret keys en el navegador.
- RLS habilitado en tablas expuestas.
- Buckets con políticas.
- Cuenta independiente por persona.
- Cuentas de prueba por rol.
- Respaldo y restauración comprobados.
- Registro de responsables y fechas.

Fuentes oficiales de Supabase consultadas

- [Auth - autenticación y autorización](#)
- [Users - identidad y access tokens](#)
- [User Management - tabla pública de perfiles](#)
- [Row Level Security](#)
- [Custom Claims y RBAC](#)
- [API keys - publishable y secret](#)
- [Custom roles en Storage](#)

Criterio final

Una interfaz puede orientar al usuario; la seguridad debe estar en la base. Para considerar un perfil listo, la barra, el guard de páginas y RLS deben coincidir.